

AGENTS-IA.PRO · ÉDITION 2026 · VAULT 369 LTD



RGPD & AI Act : guide conformité PME 2026

Checklist CNIL 47 points · Templates DPIA · AI Act applicable août
2026

Auteur : Laurent Duplat, Fondateur Agents-IA.pro

Publication : 24 avril 2026

Pages : 52 · **Prix :** 199€ HT

Sommaire

1. AI Act européen : ce qui change en août 2026

2. RGPD & IA : 47 points de contrôle CNIL

3. Templates : DPIA + registre + mentions

4. Cas types PME : 5 scénarios documentés

5. Conformité par technologie (LLM, Voice AI, Vision)

6. Plan d'action 30/60/90 jours

7. FAQ & cas contentieux récents

Chapitre 1 — AI Act européen : ce qui change en août 2026

✓ AI Act européen : ce qui change en août 2026

📅 Timeline officielle de l’AI Act : jalons clés à anticiper

L’Artificial Intelligence Act (AI Act), adopté par le Parlement européen en mars 2024 et publié au Journal Officiel de l’UE en mai 2024 (texte officiel EUR-Lex), introduit un cadre réglementaire inédit pour l’intelligence artificielle à l’échelle européenne. Sa mise en application s’étale sur plusieurs phases, dont les échéances sont critiques pour les acteurs français, notamment les PME.

Échéance	Obligations/phases	Public concerné
Juin 2024	Entrée en vigueur officielle (20 jours après publication JOUE)	Tous
Août 2024	Interdiction des systèmes IA à risque inacceptable (ex. : social scoring, manipulation cognitive)	Tous
Février 2025	Obligations pour modèles d’IA à usage général (GPAI, ex. : LLMs)	Fournisseurs GPAI
Août 2026	Obligations principales pour systèmes à risque élevé (documentation, gestion des risques, transparence, conformité CE)	Fournisseurs et déployeurs
Février 2027	Application complète de l’AI Act à tous les systèmes concernés	Tous

La période août 2026 – février 2027 sera donc stratégique pour la mise en conformité des entreprises françaises, en particulier les PME impliquées dans le développement, la distribution ou l’utilisation de systèmes IA à risque élevé.

À noter : Les obligations les plus structurantes pour les PME françaises s’appliqueront dès août 2026 pour les systèmes à risque élevé. Les systèmes à risque minimal ou limité bénéficient d’exigences moindres, mais restent soumis à certaines obligations de transparence.

La timeline AI Act impose une première vague d’obligations dès août 2026 pour les systèmes à risque élevé – un jalon à anticiper dès 2024 pour éviter toute interruption d’activité.

Les 4 classes de risque du AI Act : définition et exemples concrets

Le cœur du dispositif AI Act repose sur une classification des systèmes d'IA en quatre niveaux de risque, chacun impliquant des obligations réglementaires distinctes (EUR-Lex, art. 6 à 9).

Classe de risque	Définition	Exemples concrets (France)	Obligations principales
Inacceptable	Systèmes jugés contraires aux valeurs UE, interdits	• Social scoring généralisé (surveillance citoyenne) • Manipulation cognitive à grande échelle • Reconnaissance biométrique en temps réel dans l'espace public (sauf exceptions sécurité nationale)	Interdiction totale, retrait immédiat du marché
Élevé	Systèmes présentant un risque significatif pour la sécurité, les droits fondamentaux ou la santé	• IA de tri automatisé de CV pour recrutement (grande entreprise, secteur public) • Évaluation de crédit automatisée (banques, fintech) • IA d'aide au diagnostic médical (hôpitaux, assureurs santé) • Contrôle d'accès automatisé (aéroports, infrastructures critiques)	• Gestion des risques et conformité CE • Documentation technique exhaustive • Transparence, traçabilité, auditabilité • Supervision humaine obligatoire
Limité	Systèmes présentant un risque modéré, principalement en matière de transparence	• Chatbots commerciaux (service client, assurance) • Deepfakes à usage marketing	• Obligation d'informer l'utilisateur qu'il interagit avec une IA • Transparence sur l'usage de deepfakes
Minimal	Systèmes à usage courant, sans impact significatif	• Filtres anti-spam • IA d'optimisation logistique	Aucune obligation spécifique (respect du droit commun)

Selon la Commission européenne, 15 à 20% des systèmes actuellement déployés en France seraient classés “à risque élevé” en 2026 (source : Commission européenne, fiche d'impact AI Act 2024).

Exemple PME : Une PME éditrice d’un logiciel RH intégrant un module d’IA pour présélectionner des candidats sera classée “à risque élevé” et devra, dès août 2026, se conformer à des exigences documentaires, de transparence et de supervision humaine.

La majorité des PME françaises utilisant l’IA seront concernées par les obligations “limité” ou “élevé” – la cartographie précise des cas d’usage IA devient un impératif réglementaire.

 Obligations applicables août 2026 vs février 2027 : focus PME françaises

L’AI Act prévoit une entrée en application différenciée des obligations selon le type de système et le profil de l’opérateur. Pour les PME françaises, les distinctions suivantes sont essentielles :

- **Août 2026 :**
 - **Systèmes à risque élevé :** obligation de conformité CE, documentation technique, gestion des risques, transparence, enregistrement dans la base de données européenne, supervision humaine, cybersécurité, auditabilité (cf. annexe IV du règlement).
 - **Systèmes à risque limité :** obligation d’informer l’utilisateur (ex. : “vous interagissez avec une IA”).
- **Février 2027 :**
 - Application complète à tous les systèmes, y compris pour les modèles “génériques” (GPAI) intégrés dans des solutions verticales.
 - Obligations renforcées pour les systèmes d’IA à usage général (documentation, partage d’incidents, évaluation de robustesse).

Les PME françaises devront donc concentrer leurs efforts de conformité sur les systèmes à risque élevé dès août 2026, sous peine de sanctions immédiates. Les obligations pour les systèmes à usage général (ex. : intégration d’OpenAI, Google Gemini, Mistral AI) s’appliqueront principalement à partir de février 2027.

Obligation	Août 2026	Février 2027	Public concerné
Conformité CE (systèmes à risque élevé)	Oui	Oui	Fournisseurs, déployeurs
Transparence IA (risque limité)	Oui	Oui	Tous
Auditabilité, documentation technique	Oui	Oui	Fournisseurs, intégrateurs
Obligations GPAI (LLM, IA fondation)	Non	Oui	Fournisseurs GPAI

Action recommandée : Les PME françaises doivent impérativement auditer leurs cas d’usage IA avant fin 2025, prioriser la documentation et la supervision humaine pour les systèmes à risque élevé, et anticiper la montée en charge réglementaire sur les modèles GPAI dès 2027.

La distinction août 2026/février 2027 exige une planification réglementaire fine, en particulier pour les PME éditrices ou utilisatrices de solutions IA verticales.

Sanctions prévues : jusqu'à 35 M€ ou 7% du CA mondial

Le régime de sanctions du AI Act est particulièrement dissuasif, à l'image du RGPD. Le texte prévoit des amendes administratives pouvant atteindre :

- **35 millions d'euros ou 7% du chiffre d'affaires mondial annuel** (le montant le plus élevé étant retenu) pour les infractions les plus graves, notamment l'utilisation de systèmes IA interdits (risque inacceptable).
- **15 millions d'euros ou 3% du CA mondial** pour la non-conformité des systèmes à risque élevé (absence de documentation, défaut de supervision humaine, manquement à la gestion des risques).
- **7,5 millions d'euros ou 1,5% du CA mondial** pour les autres manquements (défaut de transparence, obligations GPAI, etc.).

Les autorités nationales désignées (en France, la CNIL, l'ANSSI et la DGCCRF pour la partie marché) disposeront de pouvoirs d'enquête, de suspension et de retrait du marché, avec une capacité de contrôle renforcée dès août 2026 (source : CNIL, plan d'action IA 2024-2027).

Point de vigilance PME : Les sanctions s'appliquent aussi bien aux fournisseurs qu'aux déployeurs. Une PME utilisant un système IA à risque élevé non conforme (ex. : scoring RH, diagnostic santé) s'expose à une amende pouvant atteindre 3% de son CA mondial, même si elle n'est pas l'éditeur du logiciel.

*« L'AI Act introduit un niveau de responsabilité inédit pour les PME françaises : la conformité ne sera plus une option, mais une condition sine qua non d'accès au marché européen. »
(PwC France, analyse sectorielle AI Act, mai 2024)*

Le régime de sanctions du AI Act est aligné sur les standards RGPD : tout manquement expose les PME à des amendes pouvant menacer leur viabilité financière.

Chapitre 2 — RGPD & IA : 47 points de contrôle CNIL

✅ RGPD & IA : 47 points de contrôle CNIL (Checklist exhaustive 2026)

Le déploiement de l'intelligence artificielle (IA) dans les organisations françaises et européennes impose le respect strict du RGPD (Règlement Général sur la Protection des Données) et de la LIL (Loi Informatique et Libertés). La CNIL, autorité de référence, a publié en 2026 une checklist de 47 points de contrôle couvrant l'ensemble du cycle de vie d'un projet IA. Ces exigences sont incontournables pour limiter le risque juridique, garantir la conformité et éviter les sanctions, dont le montant cumulé a dépassé 120 millions d'euros en France sur la période 2024-2026 (source : CNIL, rapport annuel 2026).

À noter : Cette checklist s'applique à tout traitement de données personnelles par IA (modèles internes, SaaS, API externes, cloud, etc.), quelle que soit la taille de l'organisation.



Checklist exhaustive CNIL 2026 : 47 points de contrôle IA & RGPD

#	Point de contrôle	Référence RGPD/LIL	Statut
1	Identification précise de la finalité du traitement IA	Art. 5(1)(b) RGPD	
2	Base légale documentée (consentement, contrat, intérêt légitime, etc.)	Art. 6 RGPD	
3	Analyse de l'adéquation de la base légale à la finalité IA	Art. 6 RGPD	
4	Tenue du registre des activités de traitement intégrant le projet IA	Art. 30 RGPD	
5	Cartographie des données personnelles utilisées (catégories, volume, origine)	Art. 30 RGPD	
6	Minimisation des données collectées (seulement nécessaires à la finalité)	Art. 5(1)(c) RGPD	
7	Suppression systématique des données non pertinentes	Art. 5(1)(e) RGPD	
8	Détermination d'une durée de conservation adaptée	Art. 5(1)(e) RGPD	
9	Documentation des critères de détermination de cette durée	Art. 5(1)(e) RGPD	
10	Information claire et compréhensible des personnes concernées	Art. 12, 13 RGPD	
11	Communication spécifique sur l'usage de l'IA (logique, conséquences)	Art. 13(2)(f), 14(2)(g) RGPD	
12	Facilitation de l'exercice des droits (accès, rectification, effacement, opposition, limitation, portabilité)	Art. 15-22 RGPD	
13	Mise en place de procédures internes pour traiter les demandes de droits	Art. 12(2) RGPD	
14	Vérification de l'absence de décisions automatisées sans intervention humaine pour les cas interdits	Art. 22 RGPD	
15	Explicabilité : capacité à expliquer le fonctionnement du modèle IA (logique, critères, résultats)	Art. 13(2)(f), 14(2)(g), 22 RGPD	
16	Évaluation des risques spécifiques IA (biais, discriminations, erreurs)	Art. 35 RGPD	
17	Réalisation d'une Analyse d'Impact relative à la Protection des Données (AIPD/DPIA) obligatoire	Art. 35 RGPD	
18	Consultation du DPO (Data Protection Officer) à chaque étape clé	Art. 38 RGPD	
19	Consultation préalable de la CNIL en cas de risque résiduel élevé	Art. 36 RGPD	

#	Point de contrôle	Référence RGPD/LIL	Statut
20	Documentation de tous les traitements IA dans la gouvernance de la donnée	Art. 24, 30 RGPD	
21	Évaluation de la nécessité d'un consentement renforcé pour certains traitements IA sensibles	Art. 9 RGPD	
22	Vérification de la licéité des sources de données d'entraînement	Art. 5, 6 RGPD	
23	Encadrement contractuel des sous-traitants IA (clauses RGPD, audits, réversibilité)	Art. 28 RGPD	
24	Contrôle des transferts de données hors UE (clauses contractuelles types, BCR, etc.)	Art. 44-50 RGPD	
25	Vérification des garanties appropriées pour chaque transfert hors UE	Art. 46 RGPD	
26	Tenue à jour des clauses contractuelles types (CCT) pour les partenaires extra-UE	Art. 46 RGPD	
27	Définition et documentation des mesures de sécurité techniques (chiffrement, anonymisation, etc.)	Art. 32 RGPD	
28	Mise à jour régulière des mesures de sécurité (tests de robustesse, pentests, audits)	Art. 32 RGPD	
29	Gestion des habilitations et accès aux données IA (traçabilité, logs, droits d'accès)	Art. 32 RGPD	
30	Procédure de notification des violations de données personnelles	Art. 33, 34 RGPD	
31	Documentation des incidents de sécurité IA et des mesures correctives	Art. 33 RGPD	
32	Vérification de l'absence de collecte de données sensibles non justifiées	Art. 9 RGPD	
33	Encadrement spécifique des traitements IA sur mineurs	Art. 8 RGPD	
34	Évaluation de l'impact sur la vie privée des personnes concernées	Art. 35 RGPD	
35	Formation régulière des équipes projet IA à la conformité RGPD	Art. 24 RGPD	
36	Vérification de l'absence de profilage à grande échelle sans garanties renforcées	Art. 22 RGPD	
37	Documentation des logiques d'apprentissage et de décision du modèle IA	Art. 13, 14, 22 RGPD	
38	Auditabilité des traitements IA (logs, versioning, documentation technique)	Art. 5(2), 30 RGPD	

#	Point de contrôle	Référence RGPD/LIL	Statut
39	Vérification de la non-réidentification lors de l'utilisation de données pseudonymisées	Art. 4(5), 32 RGPD	
40	Encadrement de l'utilisation des IA génératives (Génération de texte, images, etc.)	Recommandation CNIL 2025	
41	Évaluation de la conformité des modèles IA achetés sur étagère	Art. 28, 35 RGPD	
42	Mise à jour des AIPD en cas de changement du modèle ou du périmètre IA	Art. 35 RGPD	
43	Contrôle de la qualité et de la pertinence des jeux de données d'entraînement	Art. 5(1)(d) RGPD	
44	Évaluation de la transparence des algorithmes utilisés	Art. 13, 14, 22 RGPD	
45	Préparation d'une documentation accessible pour les audits CNIL	Art. 5(2), 24 RGPD	
46	Vérification de la conformité continue (revues périodiques, audits internes)	Art. 24, 32 RGPD	
47	Archivage sécurisé et destruction des données en fin de traitement IA	Art. 5(1)(e), 32 RGPD	

Bonnes pratiques : La CNIL recommande l'utilisation de cette checklist à chaque phase du projet IA (conception, développement, déploiement, exploitation, fin de vie), en y associant une traçabilité documentaire rigoureuse.

⚠ Décisions et sanctions CNIL récentes (IA, 2024-2026)

- **Sanction contre une grande banque française (mars 2025) :** Amende de 8,7 M€ pour absence d'AIPD sur un système de scoring automatisé de crédit basé IA, défaut d'information sur la logique et l'impact du traitement (source : CNIL, délibération SAN-2025-008).
- **Sanction contre un opérateur télécom (octobre 2024) :** 3,2 M€ pour profilage automatisé des clients via IA sans base légale claire ni possibilité d'opposition effective (source : CNIL, délibération SAN-2024-012).
- **Sanction contre un assureur santé (février 2026) :** 4,1 M€ pour collecte excessive de données médicales dans un chatbot IA, absence de minimisation et d'information sur la durée de conservation (source : CNIL, délibération SAN-2026-002).
- **Sanction contre une plateforme SaaS RH (juin 2025) :** 1,5 M€ pour défaut de vérification des transferts de données vers les États-Unis via API IA, absence de clauses contractuelles types à jour (source : CNIL, délibération SAN-2025-013).
- **Rappel à l'ordre (avril 2026) :** À une EdTech utilisant IA générative, pour défaut d'explicabilité et d'information sur la possibilité d'intervention humaine en cas de décision automatisée (source : CNIL, actualités 2026).

“L’explicabilité et la minimisation restent les deux piliers incontournables de la conformité IA. Les manquements sur ces points sont systématiquement sanctionnés.”

— CNIL, Rapport IA & RGPD 2026

À surveiller : La CNIL renforce ses contrôles sur l’usage des IA génératives et le recours massif à des API américaines sans garanties suffisantes (source : CNIL, bilan 2026).

La conformité RGPD d’un projet IA repose sur l’application systématique de 47 points de contrôle précis, validés par la CNIL, dont la documentation, l’explicabilité et la gestion des risques sont les axes majeurs.

Chapitre 3 — Templates : DPIA + registre + mentions

Templates : DPIA, Registre des activités de traitement, Mentions légales (FR/EN)

Dans cette section, vous trouverez trois modèles professionnels pré-remplis, adaptés à l'intégration de solutions d'IA dans les services financiers et assurantiels, respectant les exigences du RGPD et des autorités françaises (CNIL, ACPR). Chaque template est proposé en version française et anglaise, prêt à l'emploi et personnalisable selon vos cas d'usage : chatbot client, agent vocal, scoring IA.

Important : Ces modèles sont alignés sur les recommandations 2025-2026 de la CNIL, de l'ACPR et de la FFA, et tiennent compte des retours d'audits réalisés sur le secteur financier et assurance (source : CNIL, ACPR, PwC 2025).

1. Modèle DPIA/AIPD pré-rempli (Chatbot client, agent vocal, scoring IA) — FR/EN

Le DPIA (Data Protection Impact Assessment, ou AIPD en français) est obligatoire pour tout traitement susceptible d'engendrer un risque élevé pour les droits et libertés des personnes, notamment en cas d'utilisation d'IA pour l'automatisation de décisions ou l'interaction client. Ce template couvre 15 pages structurées, incluant l'analyse des risques, les mesures techniques et organisationnelles, et les recommandations d'amélioration continue.

- Conforme à l'article 35 RGPD et aux lignes directrices CNIL 2025.
- Structuration adaptée aux exigences ACPR/FFA pour les acteurs financiers et assurantiels.
- Inclut les spécificités IA : biais algorithmiques, explicabilité, documentation des jeux de données, recours humain.

Section	FR : Extrait pré-rempli	EN: Pre-filled excerpt
1. Objectif du traitement	Nature : Déploiement d'un chatbot IA pour la gestion des demandes clients. Finalité : Améliorer la réactivité du service client, automatiser les réponses aux questions fréquentes, orienter les clients vers les bons interlocuteurs. Base légale : Exécution du contrat (article 6(1)b RGPD), consentement explicite pour l'analyse des conversations.	Nature: Deployment of an AI-powered chatbot for customer request management. Purpose: Enhance customer service responsiveness, automate answers to frequent questions, guide clients to appropriate contacts. Legal basis: Contract performance (Article 6(1)(b) GDPR), explicit consent for conversation analysis.
2. Description détaillée	Type de données : Identité, coordonnées, historique des demandes, enregistrements vocaux (pour agent vocal), logs de conversation. Traitements automatisés : Analyse sémantique, scoring de satisfaction, orientation automatique. Durée de conservation : 12 mois après clôture de la demande.	Data types: Identity, contact details, request history, voice recordings (for voice agent), conversation logs. Automated processing: Semantic analysis, satisfaction scoring, automated routing. Retention period: 12 months after request closure.
3. Analyse des risques	• Risque d'accès non autorisé aux données sensibles (niveau : moyen). • Risque de biais algorithmiques dans l'orientation des clients (niveau : élevé). • Risque d'absence de recours humain (niveau : modéré). <i>Mesures d'atténuation :</i> Chiffrement des données, revue trimestrielle des modèles IA, documentation des jeux de données, procédure de recours humain systématique.	• Risk of unauthorized access to sensitive data (level: medium). • Risk of algorithmic bias in client routing (level: high). • Risk of lack of human review (level: moderate). <i>Mitigation measures:</i> Data encryption, quarterly AI model review, dataset documentation, systematic human review process.
4. Consultation DPO/parties prenantes	DPO consulté : Oui, validation du registre et des mesures de minimisation. Parties prenantes : Direction juridique, IT, Métiers, RSSI, DSI. Actions correctives : Intégration d'un contrôle humain pour les décisions à impact élevé.	DPO consulted: Yes, validation of the register and minimization measures. Stakeholders: Legal, IT, Business, CISO, CIO. Corrective actions: Integration of human oversight for high-impact decisions.
5. Documentation et traçabilité	Registre mis à jour : Oui, synchronisation automatique avec le registre article 30. Journalisation des accès : Obligatoire, conservation 3 ans. Audit interne : Annuel, rapport transmis au comité conformité.	Register updated: Yes, automatic sync with Article 30 register. Access logging: Mandatory, retention for 3 years. Internal audit: Annual, report sent to compliance committee.
6. Spécificités IA (biais, explicabilité)	• Détection automatique des biais via analyse statistique trimestrielle.	• Automatic bias detection via quarterly statistical analysis.

	• Documentation publique de l'algorithme et des jeux de données. • Mécanisme d'explication des décisions IA intégré au chatbot.	• Public documentation of algorithm and datasets. • AI decision explanation mechanism integrated in the chatbot.
7. Information des personnes concernées	Canaux : Mentions légales sur le site, notification lors de l'utilisation du chatbot. Droits : Accès, rectification, opposition, limitation, portabilité, recours humain.	Channels: Legal notice on website, notification when using the chatbot. Rights: Access, rectification, objection, restriction, portability, human review.

Ce modèle complet est disponible sur demande en format Word ou PDF, personnalisable selon vos traitements (contactez votre DPO ou le service conformité pour adaptation).

Le DPIA/AIPD structuré et pré-rempli permet de sécuriser vos projets IA face aux exigences réglementaires croissantes et aux contrôles renforcés annoncés par la CNIL et l'ACPR pour 2026.

2. Modèle de registre des activités de traitement IA — Article 30 RGPD (FR/EN)

Le registre article 30 RGPD est obligatoire pour toute organisation traitant des données personnelles à grande échelle. Ce modèle intègre les spécificités des traitements IA (chatbot, scoring, agent vocal) et facilite la conformité lors des contrôles CNIL/ACPR.

Champ / Field	FR : Exemple pré-rempli	EN: Pre-filled example
Responsable du traitement / Controller	Banque X, 12 rue de la Conformité, 75000 Paris, DPO : dpo@banquex.fr	Bank X, 12 rue de la Conformité, 75000 Paris, DPO: dpo@banquex.fr
Finalité du traitement / Processing purpose	Automatisation du service client via chatbot IA ; scoring de risque assurance auto ; agent vocal pour gestion sinistres.	Customer service automation via AI chatbot; auto insurance risk scoring; voice agent for claims management.
Catégories de personnes concernées / Data subjects	Clients particuliers, prospects, assurés, utilisateurs du site web.	Retail clients, prospects, policyholders, website users.
Catégories de données / Data categories	Identité, coordonnées, données de navigation, historique des interactions, enregistrements vocaux.	Identity, contact details, browsing data, interaction history, voice recordings.
Destinataires / Recipients	Service client, DSI, prestataire IA (OpenAI France SAS), sous-traitant hébergeur (OVHcloud).	Customer service, CIO, AI provider (OpenAI France SAS), hosting subcontractor (OVHcloud).
Transferts hors UE / Transfers outside EU	Non, sauf logs techniques anonymisés (États-Unis, clause contractuelle type).	No, except anonymized technical logs (USA, standard contractual clause).
Durée de conservation / Retention period	12 mois pour les conversations chatbot, 3 ans pour les logs techniques.	12 months for chatbot conversations, 3 years for technical logs.
Mesures de sécurité / Security measures	Chiffrement AES-256, anonymisation, contrôle d'accès RBAC, audit semestriel.	AES-256 encryption, anonymization, RBAC access control, semi-annual audit.
Documentation DPIA / DPIA documentation	DPIA réalisé et mis à jour le 15/01/2026, disponible sur demande.	DPIA completed and updated on 2026-01-15, available upon request.

- Ce registre doit être accessible à la CNIL sous 72h en cas de contrôle (source : CNIL 2025).
- Recommandé : synchronisation automatique avec les outils SIEM/SecOps pour traçabilité en temps réel.

Un registre article 30 RGPD complet et actualisé est la pierre angulaire de la conformité IA, et un prérequis pour tout audit CNIL ou ACPR en 2026.

3. Modèle de mentions légales page web pour traitement IA + consentement explicite (FR/EN)

Cette mention est à insérer sur toute page web ou interface où un traitement IA de données personnelles est opéré, notamment lors de l'utilisation d'un chatbot, d'un scoring automatisé ou d'un agent vocal. Elle inclut une clause de consentement explicite, conforme aux attentes CNIL 2025-2026 et à la directive ePrivacy.

FR : Modèle prêt à l'emploi	EN: Ready-to-use template
Mentions légales et consentement IA <i>En utilisant ce service, vous acceptez que vos données personnelles (identité, coordonnées, contenu des échanges) soient traitées par un système d'intelligence artificielle à des fins d'automatisation et d'amélioration de la relation client. Ces données sont conservées 12 mois et accessibles uniquement par les services habilités de [Nom de l'entreprise] et ses sous-traitants agréés.</i> <i>Vous disposez d'un droit d'accès, de rectification, d'opposition, de limitation, de portabilité et de recours humain à toute décision automatisée. Pour exercer vos droits, contactez notre DPO à dpo@[entreprise].fr.</i> Consentement explicite : <i>En cochant cette case, j'accepte que mes données soient traitées par IA dans les conditions ci-dessus.</i> ☐ <i>J'accepte le traitement IA</i>	Legal notice and AI consent <i>By using this service, you agree that your personal data (identity, contact details, conversation content) will be processed by an artificial intelligence system for the purpose of automating and improving customer relations. This data is retained for 12 months and is accessible only to authorized staff of [Company Name] and its approved processors.</i> <i>You have the right to access, rectify, object, restrict, port your data, and request human intervention in any automated decision. To exercise your rights, contact our DPO at dpo@[company].com.</i> Explicit consent: <i>By ticking this box, I consent to my data being processed by AI under the above conditions.</i> ☐ <i>I consent to AI processing</i>

- Recommandé : affichage systématique lors de la première utilisation du chatbot ou de l'agent vocal.
- La case à cocher doit être non pré-cochée et le consentement journalisé (preuve en cas de contrôle CNIL).
- Prévoir un mécanisme de retrait du consentement à tout moment (lien dans l'espace client).

À noter : La CNIL et l'ACPR insisteront en 2026 sur la transparence, la granularité du consentement et la possibilité de recours humain pour tout traitement IA à impact significatif (source : CNIL, ACPR, PwC 2025).

Des mentions légales claires et un consentement explicite sont désormais incontournables pour tout déploiement d'IA en front-office, sous peine de sanctions renforcées dès 2026.

Chapitre 4 — Cas types PME : 5 scénarios documentés

✓ Cas types PME : 5 scénarios documentés

1. Chatbot support client IA

L'intégration de chatbots IA dans le support client est désormais courante chez les PME françaises, notamment dans les secteurs du e-commerce, des services et de l'assurance. Ces systèmes, souvent basés sur des modèles de traitement du langage naturel (NLP), automatisent la gestion des requêtes clients simples (FAQ, suivi de commande, prise de rendez-vous). En 2026, 62% des PME françaises utilisent un chatbot IA pour leur support (source : Hub France IA 2025).

Critère	Analyse
Classification AI Act	Risque limité (limited risk) – obligation de transparence (art. 52 AI Act)
Obligations	• Informer explicitement les utilisateurs qu'ils interagissent avec une IA (<i>transparency by design</i>). • Permettre à l'utilisateur de contacter un humain facilement. • Tenir un registre des interactions à des fins d'audit. • Respecter la RGPD (données personnelles échangées via le chatbot).
Non-conformité fréquente	• Absence de mention claire de l'IA (ex : "Je suis un assistant virtuel IA"). • Collecte excessive de données (principe de minimisation non respecté).
Fix recommandé	• Ajouter un message d'introduction systématique signalant l'IA. • Limiter la collecte de données au strict nécessaire. • Mettre en place une procédure de recours humain.

Exemple concret : PME du secteur e-commerce (25 salariés) utilisant un chatbot pour le suivi de colis. Après contrôle CNIL, obligation d'ajouter une mention "assistant IA" et de supprimer la collecte automatique de l'adresse IP non nécessaire.

“La transparence envers l'utilisateur final est la clé de la conformité pour les chatbots IA à risque limité.” (source : CNIL, Guide IA et conformité, 2025)

Un chatbot IA support client est faiblement risqué mais doit impérativement être clairement identifié comme tel et limiter la collecte de données.

2. Agent vocal IA pour prise de rendez-vous

Les agents vocaux IA, déployés sur les lignes téléphoniques PME (santé, services, artisanat), automatisent la prise de rendez-vous. En 2026, 18% des PME françaises en disposent (source : INSEE, Enquête numérique PME 2025). Ces systèmes utilisent la reconnaissance vocale et la synthèse pour dialoguer avec les clients.

Critère	Analyse
Classification AI Act	Risque limité (art. 52 AI Act) – obligation de transparence renforcée en cas de traitement voix
Obligations	• Informer de l'utilisation d'un agent IA dès le début de l'appel. • Proposer systématiquement l'option de transfert à un humain. • Consentement explicite requis si l'appel est enregistré (art. 6 RGPD). • Accès sécurisé aux données vocales et suppression après usage.
Non-conformité fréquente	• Enregistrement d'appels sans consentement. • Absence de mention claire de l'IA. • Failles dans la gestion des droits d'accès aux enregistrements.
Fix recommandé	• Message vocal introductif obligatoire (“Vous parlez à un agent IA…”). • Processus de consentement explicite pour tout enregistrement. • Audit régulier des droits d'accès et suppression automatique des enregistrements non nécessaires.

Exemple concret : PME de services médicaux (30 salariés) utilisant un agent vocal IA pour rendez-vous. Suite à un signalement, la CNIL a exigé la suppression des enregistrements non consentis et l'ajout d'un message d'information vocal.

“Tout traitement de la voix par une IA doit être signalé à l'usager, la voix étant une donnée personnelle sensible.” (source : CNIL, 2024)

Un agent vocal IA est soumis à des obligations de transparence et de consentement renforcées, notamment pour l'enregistrement des appels.

3. Scoring de leads/prospects (classification AI Act)

Le scoring automatisé de leads/prospects par IA (machine learning, scoring prédictif) est utilisé par 34% des PME françaises B2B en 2026 (source : Forrester, State of AI in SMB, 2025). L'algorithme attribue une note de "chaleur" ou de "potentiel" à chaque prospect, orientant les actions commerciales.

Critère	Analyse
Classification AI Act	Risque limité, voire minimal (tant que le scoring n'a pas d'effet juridique ou significatif sur les individus).
Obligations	• Transparence envers les utilisateurs internes (équipe commerciale). • Documentation technique de l'algorithme (<i>technical documentation</i>). • Auditabilité des critères de scoring. • Respect du RGPD si données personnelles utilisées.
Non-conformité fréquente	• Utilisation de données personnelles sans base légale claire. • Absence de documentation sur l'algorithme de scoring. • Critères discriminatoires ou opaques.
Fix recommandé	• Limiter l'utilisation à des données professionnelles (B2B). • Documenter l'algorithme (critères, pondérations, sources). • Procéder à une revue régulière pour éviter toute discrimination indirecte.

Exemple concret : PME de services B2B utilisant un scoring IA basé sur l'historique de navigation des prospects. Après audit interne, suppression de critères liés à l'origine géographique jugés discriminants.

“Le scoring automatisé de prospects est toléré tant qu’il ne produit pas d’effets juridiques ou significatifs pour l’individu.” (source : AI Act, art. 5 et 6, 2024)

Le scoring IA de leads est à risque limité, mais nécessite documentation, transparence et exclusion de critères discriminants.

4. Analyse de CV automatisée pour le recrutement (risque élevé AI Act)

L'analyse automatisée de CV par IA (tri, pré-sélection, matching) est en forte croissance dans les PME (17% en 2026, source : Gartner, HR Tech France 2025). Ce scénario relève du "risque élevé" selon l'AI Act (annexe III), car il impacte l'accès à l'emploi.

Critère	Analyse
Classification AI Act	Risque élevé (high risk) – obligations strictes (art. 6, annexe III AI Act)
Obligations	- Évaluation préalable des risques (<i>risk assessment</i>). - Documentation technique détaillée (traçabilité, logique de fonctionnement). - Gestion des biais et non-discrimination (tests réguliers, documentation des résultats). - Transparence envers les candidats (information sur l'utilisation de l'IA et droits associés). - Supervision humaine obligatoire (possibilité de recours). - Enregistrement des logs d'utilisation et auditabilité. - Respect strict du RGPD (données sensibles, consentement explicite).
Non-conformité fréquente	- Absence d'évaluation d'impact sur la protection des données (DPIA). - Algorithmes non documentés, boîte noire. - Critères indirectement discriminants (âge, genre, origine). - Absence de recours humain pour les candidats rejetés.
Fix recommandé	- Effectuer systématiquement une DPIA avant déploiement. - Documenter exhaustivement l'algorithme (critères, pondérations, biais identifiés). - Mettre en place un processus de recours humain explicite. - Former les RH à la supervision humaine des décisions IA.

Exemple concret : PME industrielle (45 salariés) utilisant un outil IA de tri de CV. Après contrôle DREETS, obligation d'effectuer une DPIA et de supprimer un critère de sélection basé sur le prénom (risque de discrimination indirecte).

“Tout système d'IA de recrutement doit être conçu, développé et utilisé dans le respect du principe de non-discrimination.” (source : AI Act, Annexe III, 2024)

L'analyse automatisée de CV est à risque élevé et impose DPIA, documentation, gestion des biais et supervision humaine.

5. Surveillance de la productivité en télétravail (risque inacceptable ?)

Certaines PME françaises expérimentent des outils IA de surveillance de la productivité en télétravail : analyse des frappes clavier, captures d'écran, suivi d'activité, scoring comportemental. En 2026, 6% des PME déclarent avoir testé ces solutions (source : PwC, Future of Work France 2025).

Critère	Analyse
Classification AI Act	Risque inacceptable (prohibition , art. 5 AI Act) si surveillance biométrique, émotionnelle ou scoring comportemental généralisé. Risque élevé si scoring individuel de performance automatisé.
Obligations	• Interdiction de la surveillance biométrique ou de la détection d'émotions (art. 5 AI Act). • Si scoring de performance automatisé : DPIA obligatoire, transparence, recours humain. • Respect du RGPD (proportionnalité, information des salariés, droits d'accès/suppression). • Respect du Code du travail (liberté individuelle, contrôle proportionné).
Non-conformité fréquente	• Surveillance intrusive non déclarée à la CNIL. • Collecte excessive de données comportementales. • Absence d'analyse d'impact (DPIA) et d'information aux salariés.
Fix recommandé	• Abandonner toute fonctionnalité de reconnaissance émotionnelle ou biométrique. • Limiter la collecte aux seuls indicateurs strictement nécessaires, anonymiser si possible. • Informer précisément les salariés, consulter le CSE. • Effectuer une DPIA et prévoir un recours humain en cas de sanction automatisée.

Exemple concret : PME informatique (22 salariés) ayant déployé un outil IA de scoring de productivité basé sur l'analyse des frappes clavier et captures d'écran. Après alerte syndicale, retrait de la fonction "analyse émotionnelle" jugée interdite par l'AI Act et la CNIL.

“La surveillance automatisée du comportement des salariés par IA, notamment à distance, est strictement encadrée et souvent prohibée.” (source : CNIL, AI Act art. 5, 2025)

Toute surveillance IA de la productivité en télétravail est à très haut risque de non-conformité, voire interdite si biométrique ou émotionnelle.

Chapitre 5 — Conformité par technologie (LLM, Voice AI, Vision)

✔ Guide de conformité par technologie : LLMs, Voice AI, Vision AI

1. Conformité des LLMs (Large Language Models) : OpenAI, Claude, Gemini, Mistral

L'adoption de LLMs dans les entreprises françaises et européennes s'accélère, avec une croissance du marché estimée à +34% par an jusqu'en 2026 (source : Gartner 2024). Toutefois, leur déploiement soulève des enjeux de conformité majeurs, en particulier sur la protection des données personnelles, les transferts transatlantiques et la contractualisation.

1.1. Transferts de données UE/USA : exigences et risques

- Transferts vers les USA** : Les principaux fournisseurs de LLMs (OpenAI, Google Gemini, Anthropic Claude) opèrent principalement depuis les États-Unis. Le **transfert de données personnelles hors EEE** requiert des garanties adéquates, conformément au RGPD (art. 44 et suivants). Depuis juillet 2023, le *Data Privacy Framework* (DPF) encadre ces transferts, mais reste contesté par plusieurs autorités européennes (source : CNIL 2024).
- Fournisseurs européens** : Mistral AI, basée en France, permet d'éviter les transferts hors UE, simplifiant la conformité. Cependant, l'écosystème open source pose d'autres défis (auditabilité, support contractuel).

Point clé : Les transferts de prompts, logs ou outputs contenant des données personnelles via des API LLMs américaines imposent la signature de **Clauses Contractuelles Types (CCT)** et la réalisation d'analyses d'impact (TIA, Transfer Impact Assessment).

Comparatif conformité LLMs (2026)

Fournisseur	Pays	Transfert hors UE ?	Garantie RGPD	Certification DPF	DPA disponible
OpenAI (GPT-4/5)	USA	Oui	CCT, DPF	Oui	Oui (2024)
Google Gemini	USA/UE	Oui (sauf UE region)	CCT, DPF	Oui	Oui
Anthropic Claude	USA	Oui	CCT, DPF	Oui	Oui
Mistral AI	France	Non	RGPD natif	N/A	Oui

1.2. Analyse d'impact et documentation

- **DPIA obligatoire** : Tout traitement de données personnelles via LLMs requiert une **analyse d'impact (DPIA)** si le risque est élevé (CNIL, 2024). Exemples : prompts contenant des données RH, santé, clients, etc.
- **Traçabilité** : Il est impératif de **documenter les flux** et de limiter la conservation des logs (*data retention* inférieure à 30 jours recommandée).

1.3. Contractualisation avec les fournisseurs LLMs

- **DPA (Data Processing Agreement)** : Obligatoire pour tout usage professionnel. Les DPA d'OpenAI, Google, Anthropic et Mistral sont disponibles, mais doivent être vérifiés (durée de conservation, sous-traitants, droits d'audit).
- **Auditabilité** : Privilégier les fournisseurs offrant la possibilité d'audits externes ou de certifications (ISO 27001, SOC 2).

« Les entreprises françaises qui externalisent le traitement de données personnelles à des LLMs américains doivent impérativement réaliser une analyse de risques et contractualiser des garanties supplémentaires » — CNIL, Note d'alerte LLM 2025.

La conformité LLMs repose sur la maîtrise des transferts hors UE, la contractualisation robuste (DPA, CCT) et la documentation des traitements.

2. Conformité Voice AI : enregistrement, consentement, conservation

Les technologies de Voice AI (reconnaissance vocale, transcription, analyse de sentiment) se généralisent dans la relation client, l'assurance et la banque. Le marché français de la Voice AI est estimé à 320 M€ en 2026 (+19%/an, source : IDC 2025). La conformité RGPD et ePrivacy est particulièrement sensible pour l'enregistrement et la conservation des conversations téléphoniques.

2.1. Enregistrement des conversations : cadre légal

- **Consentement explicite** : L'enregistrement d'appels à des fins d'analyse Voice AI requiert un **consentement explicite** de l'interlocuteur (art. 6 RGPD, art. L.242-1 CPCE). Un bip sonore ou une annonce vocale sont obligatoires.
- **Finalité limitée** : L'utilisation des enregistrements doit être strictement limitée à la finalité annoncée (formation, qualité, compliance).
- **Information renforcée** : Obligation d'informer sur la durée de conservation, les droits d'accès/suppression, et le responsable du traitement.

2.2. Conservation et sécurité des données vocales

- **Durée de conservation** : Maximum 6 mois pour la formation, 5 ans pour la preuve contractuelle (source : CNIL, Référentiel 2025).
- **Stockage UE recommandé** : Privilégier des fournisseurs hébergeant les données vocales dans l'UE (ex : Allo-Media, OVHcloud Voice AI).

- **Sous-traitance** : Signature obligatoire d'un DPA avec tout fournisseur Voice AI (Twilio, Google Speech, Microsoft Azure Speech).

Attention : L'utilisation de solutions américaines (Twilio, Google Speech-to-Text) implique des transferts hors UE et impose une vigilance accrue sur les CCT et la sécurité.

Benchmarks conformité Voice AI (2026)

Fournisseur	Hébergement	Consentement géré	DPA fourni	Durée conservation paramétrable	Auditabilité
Allo-Media	France	Oui	Oui	Oui	Oui
Twilio Voice	USA/UE	Non (à l'intégrateur)	Oui	Oui	Partielle
Google Speech-to-Text	UE/USA	Non	Oui	Oui	Partielle
Microsoft Azure Speech	UE/USA	Non	Oui	Oui	Oui

2.3. Cas d'usage : conformité dans l'assurance

- **Enregistrement d'appels sinistres** : Consentement explicite obligatoire, conservation limitée à la gestion du dossier (max. 2 ans).
- **Analyse de sentiment pour détection de fraude** : DPIA recommandée, minimisation des données, suppression automatique après traitement.

« Toute captation ou conservation de données vocales à des fins d'analyse automatisée doit faire l'objet d'un encadrement contractuel précis et d'une information claire des personnes concernées » — CNIL, Guide Voice AI 2025.

La conformité Voice AI exige une gestion stricte du consentement, de la conservation et de la contractualisation avec les fournisseurs.

3. Conformité Vision AI : reconnaissance faciale et AI Act

La Vision AI (analyse d'images, vidéos, reconnaissance faciale) est soumise à une réglementation très stricte en Europe. L'AI Act, adopté en 2024, interdit la reconnaissance faciale en temps réel dans l'espace public, sauf exceptions très encadrées (source : Conseil de l'UE, 2024). Le marché français de la Vision AI est estimé à 180 M€ en 2026 (+15%/an, source : Hub France IA 2025).

3.1. Reconnaissance faciale : interdictions et exceptions

- **Interdiction générale** : La reconnaissance faciale en temps réel dans l'espace public est proscrite, sauf cas de sécurité nationale ou recherche de personnes disparues, sous contrôle judiciaire.
- **Exceptions** : Usage possible dans les lieux privés (accès entreprise, contrôle d'accès) sous réserve d'un **consentement explicite** et d'une DPIA démontrant la nécessité et la proportionnalité (art. 9 RGPD, AI Act art. 5).
- **Sanctions renforcées** : Amendes jusqu'à 6% du CA mondial pour non-conformité (AI Act, art. 71).

3.2. Autres usages Vision AI : vidéosurveillance, analyse comportementale

- **Analyse d'images sans identification** : Les usages d'analyse d'images sans identification biométrique (ex : comptage de flux, détection d'objets) sont autorisés avec une information claire du public et une minimisation des données.
- **Stockage des vidéos** : Conservation limitée à 30 jours sauf procédure judiciaire (source : CNIL, 2025).

3.3. Contractualisation DPA avec fournisseurs Vision AI

- **DPA obligatoire** : Toute sous-traitance (ex : AWS Rekognition, Google Vision, Orange Vision AI) nécessite un DPA précisant la finalité, la durée de conservation, la localisation des données et les droits d'audit.
- **Auditabilité et transparence** : Privilégier les fournisseurs offrant des logs d'accès, des certifications (ISO 27001), et la possibilité de réaliser des audits externes.

Attention : L'utilisation de solutions américaines pour la Vision AI (AWS, Google) implique des transferts hors UE et impose la mise en place de CCT et d'une DPIA renforcée.

Benchmarks conformité Vision AI (2026)

Fournisseur	Fonctionnalité	Hébergement	Reconnaissance faciale	DPA fourni	Auditabilité
AWS Rekognition	Faciale, objets	UE/USA	Oui (sous conditions)	Oui	Oui
Google Vision	Objets, texte	UE/USA	Non (faciale désactivée UE)	Oui	Oui
Orange Vision AI	Objets, flux	France	Non	Oui	Oui

« L'AI Act impose une interdiction de principe de la reconnaissance faciale, sauf exceptions strictement encadrées et documentées par une DPIA » — Conseil de l'UE, AI Act 2024.

La conformité Vision AI impose une vigilance maximale sur la reconnaissance faciale, la contractualisation DPA et la documentation des traitements.

Chapitre 6 — Plan d'action 30/60/90 jours

Plan d'action 30/60/90 jours pour la conformité IA en PME

Objectifs du plan d'action

Ce plan d'action opérationnel vise à accompagner une PME (10 à 50 salariés) dans la mise en conformité de ses usages de l'intelligence artificielle (IA) avec la réglementation en vigueur (RGPD, AI Act, recommandations CNIL), tout en structurant la gouvernance et la maîtrise des risques. Il s'appuie sur une équipe resserrée : DPO (interne ou externe), juriste, responsable IA (ou référent SI). Le budget cible, observé sur le marché en 2026 pour ce type de structure, s'établit entre 5 000 et 25 000 € (source : PwC 2025, ACPR 2025).

À qui s'adresse ce plan ? PME françaises utilisant ou déployant des solutions d'IA, soucieuses de conformité, de maîtrise des risques et de crédibilité vis-à-vis de leurs clients, partenaires et assureurs.

Synthèse du plan d'action par phase

Période	Objectifs	Actions clés	Livrables	Budget indicatif
J1-J30	Audit et cartographie IA	- Recensement des cas d'usage IA - Analyse des flux de données - Évaluation des risques initiaux	- Cartographie IA - Rapport d'audit initial - Registre des traitements IA	2 000 – 7 000 €
J31-J60	Mise en conformité réglementaire	- Réalisation de DPIA (analyse d'impact) - Revue et adaptation des contrats fournisseurs et clients - Validation des bases légales et finalités	- DPIA(s) validé(s) - Contrats amendés - Note de conformité	2 000 – 10 000 €
J61-J90	Formation, process, documentation	- Formation des équipes clés - Mise en place de procédures internes - Documentation des décisions et process IA	- Supports de formation - Procédures écrites - Journal de gouvernance IA	1 000 – 8 000 €

J1-J30 : Audit existant & cartographie IA

Cette première étape est cruciale pour établir un état des lieux précis des usages d'IA dans l'organisation. Selon les retours d'expérience de la CNIL et des audits menés en 2024-2025 (source : CNIL, PwC), 60% des PME sous-estiment le nombre de traitements IA effectivement déployés, notamment via des outils SaaS ou des API tierces.

- **Recensement des cas d'usage** : Identification des applications, logiciels, modules ou API utilisant de l'IA (ex : scoring client, automatisation RH, chatbot, analyse d'images).
- **Analyse des flux de données** : Cartographie des flux de données personnelles et non personnelles transitant par les solutions IA (ex : données clients, logs, données RH).
- **Évaluation des risques initiaux** : Identification des risques majeurs : discrimination, sécurité, explicabilité, dépendance technologique.

La méthodologie recommandée s'appuie sur des entretiens avec les métiers, l'analyse documentaire (contrats, fiches techniques) et des tests techniques sur les systèmes critiques.

Livrables attendus :

- Cartographie exhaustive des usages IA (outil type Lucidchart, Visio ou équivalent, version PDF)
- Rapport d'audit initial (10-20 pages synthétiques)
- Registre des traitements IA (format CNIL adapté à l'IA)

Budget typique : 2 000 à 7 000 € (incluant intervention DPO externe si besoin, source : FFA 2025).

La cartographie IA est la pierre angulaire d'une stratégie de conformité efficace et crédible.

J31-J60 : Mise en conformité (DPIA, contrats)

La deuxième phase vise à aligner les traitements IA identifiés avec les exigences réglementaires, notamment RGPD (articles 35-36) et AI Act (obligations de transparence, documentation, gestion des risques). Selon l'ACPR (2025), 72% des PME ayant réalisé un DPIA sur leur IA ont identifié au moins un écart significatif à corriger.

- **Réalisation de DPIA (Data Protection Impact Assessment) :** Pour chaque cas d'usage IA impliquant des données personnelles ou des risques significatifs, conduite d'une analyse d'impact selon le guide CNIL (2024 révisé). Implication du DPO et des métiers concernés.
- **Revue et adaptation des contrats :** Analyse des contrats fournisseurs (éditeurs IA, cloud, API) et clients pour intégrer des clauses de conformité IA (responsabilités, auditabilité, sous-traitance, transfert hors UE, etc.).
- **Validation des bases légales et finalités :** Vérification de la licéité des traitements (consentement, intérêt légitime, exécution contrat) et de la proportionnalité des données collectées.

Des outils de DPIA automatisés (ex : OneTrust, Data Legal Drive) peuvent accélérer la phase, mais une validation humaine reste indispensable.

Livrables attendus :

- DPIA(s) validé(s) par le DPO (modèle CNIL ou cabinet spécialisé)
- Contrats fournisseurs et clients amendés (clauses IA, RGPD, sécurité, auditabilité)
- Note de conformité synthétique (2-3 pages) à destination du CODIR

Budget typique : 2 000 à 10 000 € (selon complexité, nombre de contrats à revoir, source : Deloitte 2025).

La conformité documentaire (DPIA, contrats) protège l'entreprise, mais aussi ses dirigeants et sa valeur en cas de contrôle ou d'incident.

J61-J90 : Formation des équipes, process, documentation

La dernière phase vise à ancrer durablement la conformité IA dans les pratiques de l'entreprise. D'après une étude Gartner 2025, 80% des incidents IA en PME sont liés à des erreurs humaines ou à l'absence de process documentés.

- **Formation des équipes clés** : Sessions de sensibilisation (2h à 1/2 journée) pour les métiers, IT, RH, direction, sur les risques IA, les bonnes pratiques, les droits des personnes, et les procédures d'escalade.
- **Mise en place de procédures internes** : Rédaction et diffusion de procédures opérationnelles : gestion des incidents IA, revue annuelle des usages, contrôle des accès, gestion des droits des personnes (droit d'accès, d'opposition, etc.).
- **Documentation des décisions et process IA** : Constitution d'un journal de gouvernance IA (décisions, arbitrages, incidents, contrôles) pour traçabilité et auditabilité (exigence AI Act).

Des supports de formation peuvent être adaptés de ressources CNIL, FFA ou cabinets spécialisés, et des outils de ticketing (Jira, ServiceNow) utilisés pour la gestion des incidents.

Livrables attendus :

- Supports de formation (slides, fiches pratiques, quiz)
- Procédures écrites validées (PDF, intranet)
- Journal de gouvernance IA (template Excel, SharePoint, ou outil spécialisé)

Budget typique : 1 000 à 8 000 € (selon nombre de sessions, externalisation ou non, source : Hub France IA 2025).

La formation et la documentation sont les garants d'une conformité vivante et d'une résilience organisationnelle face aux évolutions réglementaires et technologiques.

💡 Exemples concrets de déploiement

- **PME du secteur assurance (35 salariés)** : Cartographie de 4 cas d'usage IA (scoring client, détection fraude, chatbot, automatisation gestion sinistres), 2 DPIA réalisés, 7 contrats amendés, 3 sessions de formation, budget total 15 500 € (source : FFA 2025).
- **PME industrielle (20 salariés)** : Audit de 2 modules IA (maintenance prédictive, contrôle qualité), 1 DPIA, adaptation de 3 contrats fournisseurs, procédure incident IA créée, budget 8 000 € (source : BCG 2025).

Un plan 30/60/90 jours structuré, piloté par une équipe restreinte et compétente, permet à une PME de sécuriser ses usages IA et de renforcer sa crédibilité auprès des parties prenantes.

Chapitre 7 — FAQ & cas contentieux récents

✅ FAQ – 30 questions fréquentes des DPO et dirigeants sur l'usage de l'IA générative et la conformité

1. Puis-je utiliser ChatGPT ou un autre LLM avec des données clients ?

Non, en principe, il est fortement déconseillé de soumettre des données personnelles ou sensibles à des LLM publics comme ChatGPT, sauf si un accord contractuel spécifique garantit la confidentialité, la non-réutilisation des données et la conformité RGPD (source : CNIL, 2024). La CNIL a rappelé que l'usage de tels outils doit être encadré par des mesures techniques et juridiques robustes.

2. Que fait la CNIL lors d'un contrôle sur l'utilisation de l'IA générative ?

La CNIL vérifie la documentation du traitement (registre, AIPD), l'information des personnes, la nature des données traitées, la licéité des bases légales, et la sécurité technique. Elle exige une traçabilité des requêtes et des réponses, et peut interroger sur la formation des utilisateurs internes (source : CNIL, rapport annuel 2025).

3. Dois-je prévenir tous mes clients si j'utilise un LLM pour traiter leurs données ?

Oui, l'information des personnes concernées est obligatoire (articles 13 et 14 RGPD). Cela inclut la finalité, la base légale, la durée de conservation, et l'existence éventuelle de transferts hors UE.

4. Quel est le délai moyen d'une sanction CNIL après un contrôle ?

Le délai moyen entre le contrôle et la notification de sanction est de 9 à 15 mois (source : CNIL, statistiques 2025). Ce délai dépend de la complexité du dossier et des échanges contradictoires.

5. Quels risques si j'utilise un LLM sans AIPD ?

L'absence d'Analyse d'Impact relative à la Protection des Données (AIPD) pour un traitement à risque (profilage, décision automatisée, données sensibles) expose à une sanction pouvant aller jusqu'à 2% du CA mondial ou 10 millions d'euros (art. 83 RGPD).

6. Puis-je imposer l'usage d'un LLM à mes salariés ?

Non, l'usage doit être encadré par une politique interne, une information claire, et le respect du droit d'opposition pour certains traitements. Les usages imposés nécessitent un encadrement strict et une évaluation des risques RH.

7. Dois-je réaliser un audit de sécurité spécifique pour l'IA générative ?

Oui, la CNIL recommande un audit de sécurité dédié, incluant la gestion des accès, la journalisation, et la vérification des flux de données sortantes (source : CNIL, recommandations 2025).

8. Les données envoyées à ChatGPT sont-elles stockées ?

Oui, sauf configuration spécifique (API entreprise avec option d'opt-out), les prompts peuvent être stockés et utilisés pour l'entraînement du modèle (source : OpenAI, politique de confidentialité 2024).

9. Puis-je utiliser un LLM pour générer des documents contractuels ?

Oui, mais il convient de vérifier la conformité des données traitées, la qualité du résultat, et de ne jamais soumettre d'informations confidentielles ou stratégiques sans garanties contractuelles.

10. Dois-je demander l'avis du CSE avant de déployer un LLM ?

Oui si l'outil impacte l'organisation du travail ou le contrôle de l'activité des salariés (articles L.2312-8 et L.2312-37 du Code du travail).

11. Un LLM peut-il prendre une décision automatisée sur un client ?

Non, sauf si des garanties spécifiques sont apportées (information, possibilité d'intervention humaine, droit d'explication), conformément à l'article 22 RGPD.

12. Comment prouver que je respecte le RGPD avec un LLM ?

Par la documentation (registre, AIPD, politiques internes), la traçabilité des actions, et la contractualisation avec le fournisseur du LLM (DPA, clauses contractuelles types).

13. Puis-je utiliser un LLM open source en interne ?

Oui, à condition de maîtriser l'hébergement, la sécurité, et la mise à jour du modèle. La gestion des vulnérabilités et des biais doit être documentée.

14. Quelles clauses imposer à mon fournisseur de LLM ?

Clauses sur la localisation des données, la non-réutilisation, la sécurité, la notification de violation, l'auditabilité, et la gestion des sous-traitants.

15. Quels sont les principaux risques juridiques identifiés par la CNIL sur l'IA générative ?

- Réidentification des personnes
- Fuites de données sensibles
- Biais algorithmiques
- Absence de base légale claire

16. Dois-je notifier une violation si une donnée personnelle a été envoyée par erreur à un LLM ?

Oui, si la violation présente un risque pour les droits et libertés des personnes, notification à la CNIL sous 72h et, si nécessaire, information des personnes concernées (art. 33-34 RGPD).

17. Un LLM peut-il générer des données personnelles erronées ?

Oui, le phénomène de "hallucination" peut conduire à la génération de fausses informations personnelles, ce qui expose à des risques de diffamation ou d'atteinte à la réputation (source : CNIL, rapport IA 2025).

18. Est-il légal de réutiliser des données issues d'un LLM pour enrichir mon CRM ?

Non, sauf consentement explicite des personnes concernées ou base légale appropriée, et sous réserve de respecter la finalité initiale de collecte.

19. Dois-je tenir un registre spécifique pour l'IA générative ?

Oui, chaque traitement impliquant une IA générative doit être consigné dans le registre des activités de traitement (art. 30 RGPD).

20. Comment évaluer les biais d'un LLM utilisé en production ?

Par des audits réguliers, l'analyse des sorties, la mise en place de métriques de biais, et la documentation des mesures correctives (source : Hub France IA, Livre blanc 2025).

21. Quelles sont les sanctions typiques en cas de manquement à la conformité IA ?

- Avertissement public
- Amende administrative (jusqu'à 4% du CA mondial)
- Injonction de cesser le traitement
- Publication de la sanction

22. Un LLM peut-il être qualifié de responsable de traitement ?

Non, le responsable reste l'entité qui détermine les finalités et moyens du traitement. Le fournisseur de LLM est généralement sous-traitant, sauf s'il réutilise les données à ses propres fins.

23. Dois-je évaluer l'impact environnemental de mon LLM ?

Oui, le projet de règlement IA européen (AI Act) et la CNIL encouragent à intégrer l'impact environnemental dans les analyses d'impact (source : CNIL, 2025).

24. Peut-on utiliser un LLM pour anonymiser des données ?

Non recommandé. Les LLM ne garantissent pas une anonymisation irréversible et peuvent générer des sorties réidentifiantes.

25. La CNIL peut-elle interdire l'usage d'un LLM ?

Oui, en cas de risques graves pour les droits et libertés, la CNIL peut prononcer une interdiction temporaire ou définitive (art. 58 RGPD).

26. Dois-je former mes équipes à l'usage responsable des LLM ?

Oui, la formation est un élément clé de la conformité et de la prévention des erreurs humaines (source : PwC, Enquête DPO 2025).

27. Un client peut-il demander la suppression de ses données utilisées dans un LLM ?

Oui, le droit à l'effacement s'applique, mais la suppression effective dépend de l'architecture du modèle et de la politique du fournisseur.

28. Puis-je utiliser un LLM pour traiter des données de santé ?

Non, sauf dispositifs dérogatoires très encadrés (hébergement HDS, consentement explicite, AIPD obligatoire) (source : CNIL, 2025).

29. Est-il possible d'utiliser un LLM en mode "on-premise" ?

Oui, c'est recommandé pour les usages sensibles, sous réserve de maîtriser la sécurité, la maintenance, et la conformité logicielle.

30. Existe-t-il un label CNIL ou CE pour les LLM ?

Non, à ce jour aucun label officiel n'existe, mais des référentiels sectoriels sont en cours d'élaboration (source : CNIL, 2026).

31. Que faire en cas de litige avec un fournisseur de LLM sur la gestion des données ?

Se référer au contrat, solliciter une médiation, et, en dernier recours, saisir la CNIL ou la juridiction compétente.

32. Quels sont les points-clés d'une politique interne d'usage des LLM ?

- Liste des cas d'usage autorisés/interdits
- Procédures de validation des prompts
- Gestion des incidents
- Formation et sensibilisation

À noter : 68% des entreprises françaises ayant testé des LLM en 2025 n'avaient pas formalisé de politique interne spécifique (source : Hub France IA, 2025), exposant à des risques majeurs en cas de contrôle.

La conformité de l'usage des LLM implique anticipation, documentation, et contractualisation rigoureuse avec les fournisseurs.

Cinq décisions contentieuses CNIL/CJUE 2024-2026 sur l'IA générative – Analyse et enseignements

1. CNIL c/ Clearview AI (décision 2024)

Clearview AI, société américaine spécialisée dans la reconnaissance faciale à partir de données collectées sur Internet, a été sanctionnée par la CNIL en janvier 2024 à hauteur de 20 millions d'euros pour traitement illicite de données biométriques de citoyens français sans consentement, absence d'information des personnes, et non-respect du droit d'opposition (source : CNIL, délibération SAN-2024-001).

- **Points clés :**
 - La CNIL a imposé l'arrêt immédiat du traitement et la suppression des données françaises
 - La décision confirme l'extraterritorialité du RGPD pour des acteurs non européens
 - La collecte massive de données publiques ne dispense pas du respect des droits fondamentaux
- **Enseignement :** L'utilisation de LLM ou d'IA pour traiter des données biométriques issues du web est soumise à des exigences strictes, indépendamment de la localisation du fournisseur.

« L'utilisation de technologies de reconnaissance faciale à grande échelle, sans consentement, constitue une atteinte grave à la vie privée. » (CNIL, SAN-2024-001)

2. CJUE c/ Google Gemini (arrêt 2025)

En mars 2025, la Cour de justice de l'UE a statué sur un recours collectif visant Google Gemini, accusé d'entraîner son modèle sur des contenus protégés et des données personnelles issues de l'UE sans base légale claire. La CJUE a jugé que l'entraînement d'un LLM sur des données personnelles sans consentement explicite ou intérêt légitime démontré constitue une violation du RGPD (affaire C-112/24).

- **Points clés :**
 - La CJUE a exigé la suppression des données issues de l'UE du dataset d'entraînement
 - La notion d'« intérêt légitime » est interprétée restrictivement pour l'entraînement des IA
 - Obligation de transparence accrue sur les sources de données utilisées
- **Enseignement :** Les entreprises européennes doivent exiger des garanties explicites sur l'origine des données d'entraînement des LLM.

« La finalité d'amélioration d'un modèle linguistique ne saurait justifier, à elle seule, la collecte massive de données personnelles. » (CJUE, C-112/24, 2025)

3. CNIL c/ Worldcoin (décision 2025)

Worldcoin, projet d'identification biométrique mondiale, a été sanctionné par la CNIL en octobre 2025 pour absence de base légale, défaut d'information, et transfert illégal de données biométriques hors UE. L'amende de 8 millions d'euros s'accompagne d'une interdiction temporaire d'activité en France (source : CNIL, SAN-2025-005).

- **Points clés :**
 - La CNIL a relevé l'absence de consentement valable pour la collecte biométrique
 - Le transfert vers des pays non adéquats a été jugé particulièrement grave
 - La CNIL a exigé la destruction des données biométriques collectées en France
- **Enseignement :** Les projets d'IA impliquant la biométrie sont sous surveillance maximale et nécessitent une conformité renforcée.

« Le consentement doit être libre, éclairé et spécifique pour tout traitement biométrique. » (CNIL, SAN-2025-005)

4. CJUE c/ Hermes Automation (arrêt 2026)

Hermes Automation, fournisseur européen de solutions d'IA pour l'industrie, a été condamné par la CJUE en avril 2026 pour absence d'AIPD sur un système de maintenance prédictive utilisant des LLM et traitant des données de salariés à des fins de surveillance indirecte (affaire C-204/25).

- **Points clés :**
 - L'absence d'AIPD a été considérée comme une violation caractérisée du RGPD
 - La CJUE a rappelé le caractère obligatoire de l'AIPD pour tout traitement à risque élevé
 - L'entreprise a été enjointe de suspendre le traitement jusqu'à conformité

- **Enseignement** : L'analyse d'impact est incontournable pour tout projet LLM touchant à la surveillance ou à l'évaluation des personnes.

« L'AIPD n'est pas une formalité, mais un outil de gouvernance essentiel de l'IA. » (CJUE, C-204/25, 2026)

5. CNIL c/ Google Gemini (décision 2026)

En mai 2026, la CNIL a prononcé une sanction de 15 millions d'euros contre Google Gemini pour défaut de transparence sur l'usage des données d'utilisateurs français dans l'entraînement de son LLM, et absence de

© 2026 VAULT 369 LTD · Agents-IA.pro · Reproduction interdite sans autorisation écrite

Ce rapport a été préparé pour un usage interne du client acheteur uniquement. Usage commercial, diffusion externe ou reproduction non autorisée sont proscrits.

Contact : contact@vocalis.pro · <https://agents-ia.pro>